CCTV

Plataforma: HackTheBox
Dificuldade: Fácil
Data de Resolução: 18 de abril de 2026

Sumário

1. Visão Geral ……. 3
2. Reconhecimento ……. 3
3. Exploração ……. 4
4. Escalada de Privilégios …….. 8
5. Conclusão ……... 8
6. Referências ……. 8

1. Visão Geral

A máquina CCTV apresenta um cenário de exploração web focado no comprometimento de um sistema de videomonitoramento. O ataque consistiu no mapeamento inicial de serviços, descoberta de um endpoint oculto hospedando o software ZoneMinder, e obtenção de acesso administrativo valendo-se de credenciais padrão. A partir da sessão autenticada, a superfície de ataque principal foi explorada através de uma vulnerabilidade de Injeção de SQL (CVE-2024-51482), traçando o caminho geral de extração de credenciais de alto privilégio do banco de dados da aplicação web.

2. Reconhecimento

A investigação externa começou com uma varredura para identificar portas abertas e serviços rodando na máquina alvo.

```bash
nmap -p- -sV --min-rate 5000 <TARGET_IP> -vvv
```

Justificativa: O Nmap foi instruído a escanear todas as 65535 portas (-p-) em busca da versão dos serviços em execução (-sV). A flag --min-rate 5000 garante uma execução acelerada da varredura, e -vvv exibe os resultados em tempo real na tela.

Output:

```plaintext
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.6p1 Ubuntu
3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.58
```

Diante da presença de um servidor web na porta 80, realizou-se a enumeração de diretórios para descobrir possíveis painéis administrativos ou arquivos ocultos da aplicação.

```bash
gobuster dir -u "http://<TARGET_IP>" -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

```
-x php,txt,html
```

Justificativa: O Gobuster realiza requisições massivas testando nomes de pastas a partir de um dicionário. A flag -x amplia a busca para incluir arquivos com extensões comuns no desenvolvimento web (PHP, TXT e HTML), maximizando as chances de descobrir arquivos deixados pela administração.

Output:

```Plaintext
4c208d8c => 302 (redirect to
http://cctv.htb/2374e02a-e3a8-41ce-9542-4c514c208d8c)
```

3. Exploração

A enumeração indicou que o servidor faz roteamento virtual de hosts apontando para o domínio cctv.htb. Ajustou-se o host local do atacante para permitir a resolução desse endereço.

```Bash
echo "<TARGET_IP> cctv.htb" | sudo tee -a /etc/hosts
```

Justificativa: O comando adiciona um mapeamento direto do endereço IP para a URL cctv.htb, viabilizando que o navegador processe corretamente as requisições HTTP exigidas pelo servidor web Apache.

O acesso direto à URL através de um navegador exibiu a interface central de uma empresa de monitoramento.

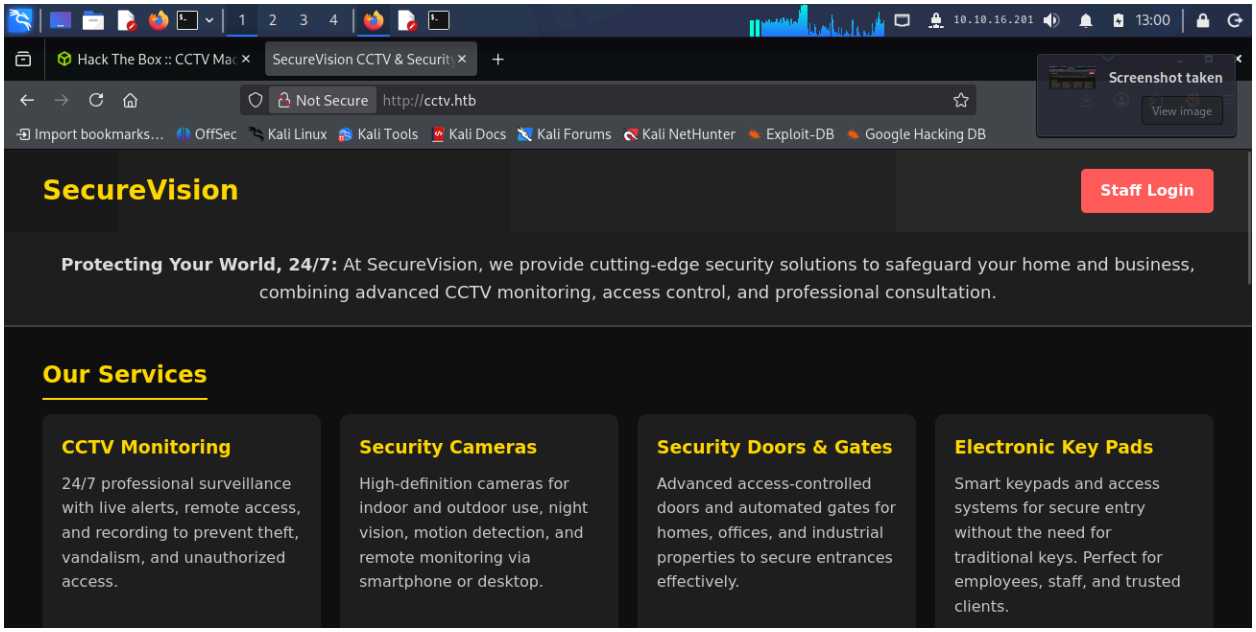

Figura 1: Página inicial da aplicação web CCTV, exibindo apresentação institucional e áreas de navegação da corporação.

Identificou-se um ponto de interação crítico no canto superior direito: um botão intitulado "Staff Login". Esse botão encaminhava diretamente ao endpoint de administração do sistema, em http://cctv.htb/zm/.

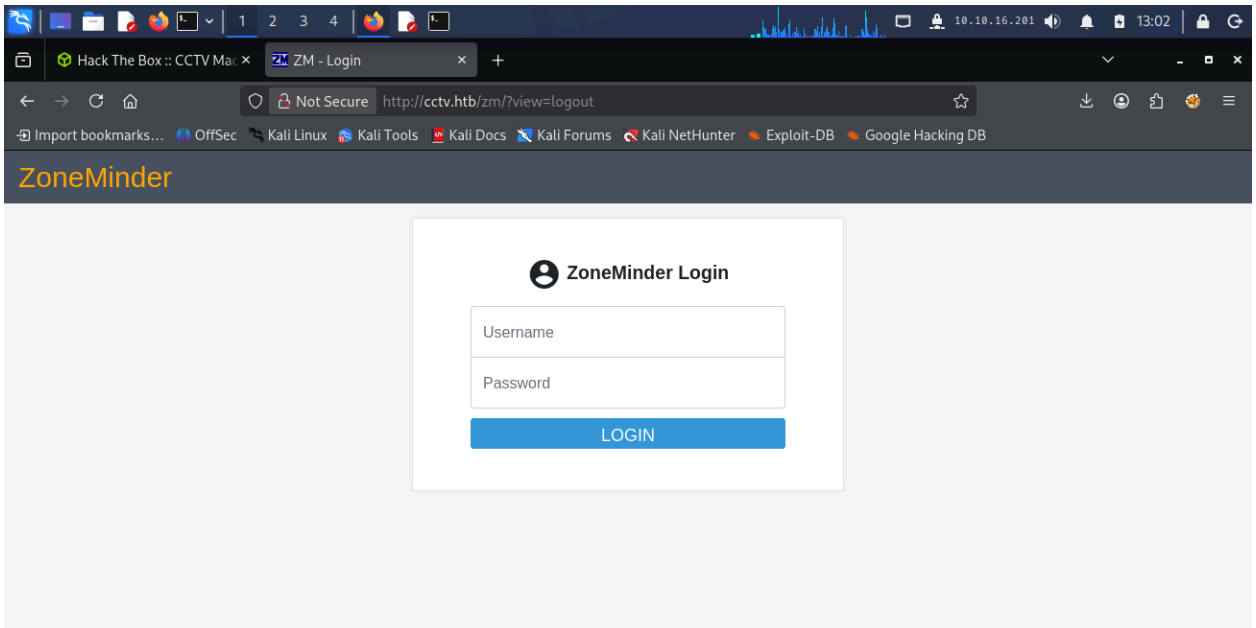

Figura 2: Portal de autenticação evidenciando a tecnologia subjacente do serviço.

A página de login expunha que a infraestrutura operava sob o sistema **ZoneMinder**. Trata-se de

um software robusto, popular e de código aberto dedicado a monitoramento e gravação de segurança por circuito fechado de televisão (CCTV) integrado a câmeras IP. É frequentemente utilizado em redes corporativas para compilar fluxos de câmeras e emitir alertas analíticos de segurança.

Explorando o erro de hardening de configurações, o acesso ao painel de gerenciamento foi obtido rapidamente enviando o payload mais trivial em sistemas de teste: o usuário e a senha padrão admin.

Já na sessão de administrador, a enumeração interna dos painéis de controle revelou a versão exata do software como **1.37.63**. Uma consulta a bases de dados públicas de vulnerabilidades identificou que esta edição é suscetível à **CVE-2024-51482**, uma grave falha de *SQL Injection* autenticada originada de validações falhas em certas requisições da interface web.

A fim de realizar o dump das credenciais, primeiramente capturou-se o cookie da sessão válida obtida anteriormente utilizando o inspecionador de elementos do navegador no caminho de índice da aplicação.

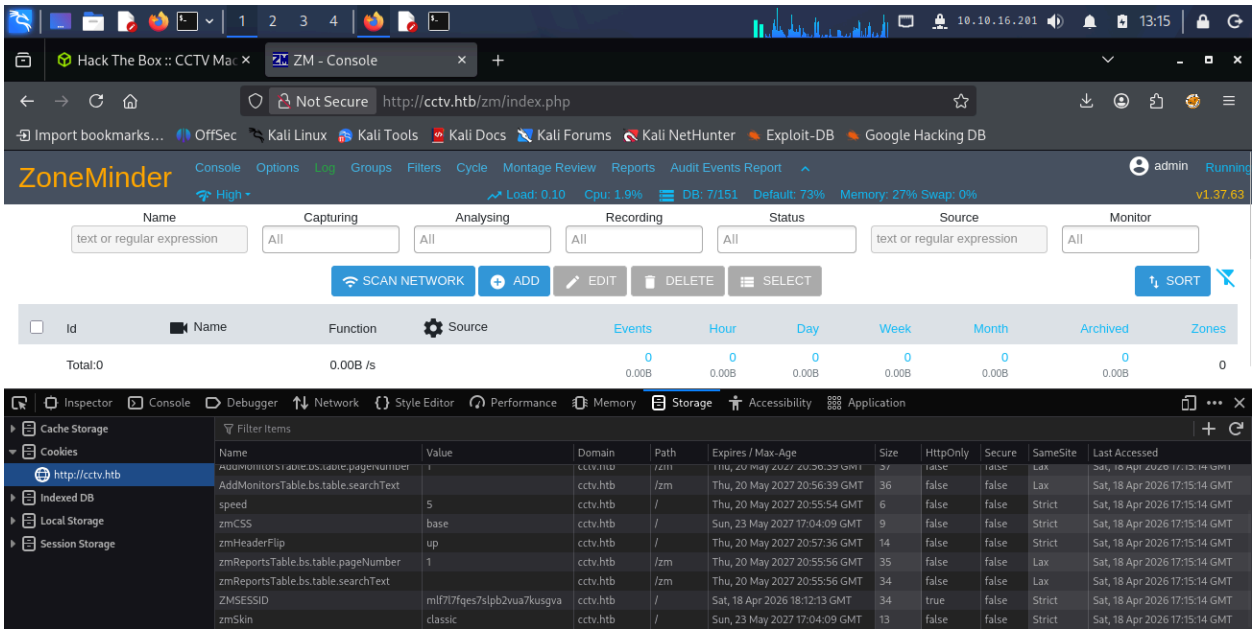

Figura 3: Ferramentas de Desenvolvedor (DevTools) ilustrando a captura da chave de acesso e sessão, necessária para o bypass no script de injeção.

De posse do token, disparou-se a ferramenta automatizada sqlmap para explorar a falha em um dos endpoints suscetíveis de remoção de tags:

```
Bash
```

```
sqlmap -u
"http://cctv.htb/zm/index.php?view=request&request=event&actio
n=removetag&tid=1" \
-D zm -T Users -C Username,Password --dump --batch \
--dbms=MySQL --technique=T \
--cookie="ZMSESSID=<USER_COOKIE>" \
--time-sec=2
```

Justificativa dos parâmetros utilizados:

- -u: Aponta para a URL vulnerável e especifica o parâmetro a ser explorado nas requisições do sistema.
- -D zm: Seleciona unicamente o banco de dados principal do serviço (zm).
- -T Users: Isola a busca e ataque para dentro da tabela específica de usuários.
- -C Username,Password: Otimiza o processo exigindo extração apenas das colunas correspondentes de nome de usuário e hash de senha criptografada.
- --dump: Comando de execução que ordena a extração e exibição local do conteúdo encontrado.
- --batch: Omitirá respostas manuais por responder como default as perguntas do prompt, rodando de modo autônomo.
- --dbms=MySQL: Acelera o reconhecimento da sintaxe informando preventivamente o motor do banco de dados utilizado.
- --technique=T: Força a ferramenta a usar exclusivamente a técnica Baseada no Tempo (Time-Based), útil em injeções em que falhas lógicas e de erro são mitigadas pelo servidor, baseando acertos pelo atraso da rede.
- --cookie: Injeta na requisição o cookie interceptado, permitindo que as consultas possuam a autorização administrativa exigida pela CVE.
- --time-sec=2: Parâmetro estatístico instruindo a ferramenta que respostas adiadas por mais de dois segundos sinalizam a injeção correta.

A varredura concluiu com sucesso extraindo da tabela três registros, sendo dois em branco, conforme abaixo truncado (os dados críticos foram omitidos):

```
Plaintext
+------------+-----------------------------------------------
--------------+
| Username   | Password
|
+------------+-----------------------------------------------
--------------+
```

```
| superadmin | <HASH>
|
| <blank>    | <HASH>
|
| <blank>    | <blank>
|
+------------+-----------------------------------------------
--------------+
```

Este vetor de ataque viabilizou apenas a enumeração de uma conta do mais alto privilégio na aplicação (superadmin), falhando em promover credenciais sistêmicas locais que pudessem ser empregadas em serviços subjacentes para acesso shell, como o SSH.

4. Escalada de Privilégios

Não aplicável. O comprometimento pleno da máquina por explorações de privilégios e binários (*Privilege Escalation*) não chegou a ser concretizado perante a falta de *foothold* na via de rede ou console administrativo com RCE.

5. Conclusão

A progressão da exploração na CCTV reflete os imensos perigos da manutenção de credenciais padrão corporativas e aplicações sem atualizações críticas. O reconhecimento da infraestrutura possibilitou o desvio de controles do ZoneMinder, e através do aproveitamento ativo de uma vulnerabilidade autenticada, estabeleceu-se um vazamento massivo de banco de dados (SQLi) com êxito na leitura completa de hashes de perfil administrador, encerrando a linha principal da intrusão.

6. Referências

- Aviso do NIST detalhando a falha no ZoneMinder: NVD - CVE-2024-51482